

Latest DNS Vulnerabilities

We can find thousands of subdomains and domains on the web. Often they point to no longer active third-party services like AWS, GitHub, and others and, at best, display an error message as confirmation of a deactivated third-party service. These corporations are also affected time and again. Companies often cancel services from third-party providers and forget to remove associated DNS records. This is because no additional costs are incurred for a DNS entry. Many well-known bug bounty programs, as [HackerOne](#), already explicitly list [Subdomain Takeover](#) as a bounty category. With a simple search, we can find tools, for example, that automate the discovery of vulnerable subdomains or help create Proof of Concepts (PoCs) for the bug bounty program of our choice or the affected company. RedHuntLabs did a [study](#) on this in 2020, and found that 400,000 subdomains out of 220 million were vulnerable to subdomain takeover. 62% of them belonged to

RedHuntLabs Study

33

third party services that are
prone to allow Subdomain
Takeover vulnerability..

220 MILLION

domains/subdomains
studied to understand
and posture of this

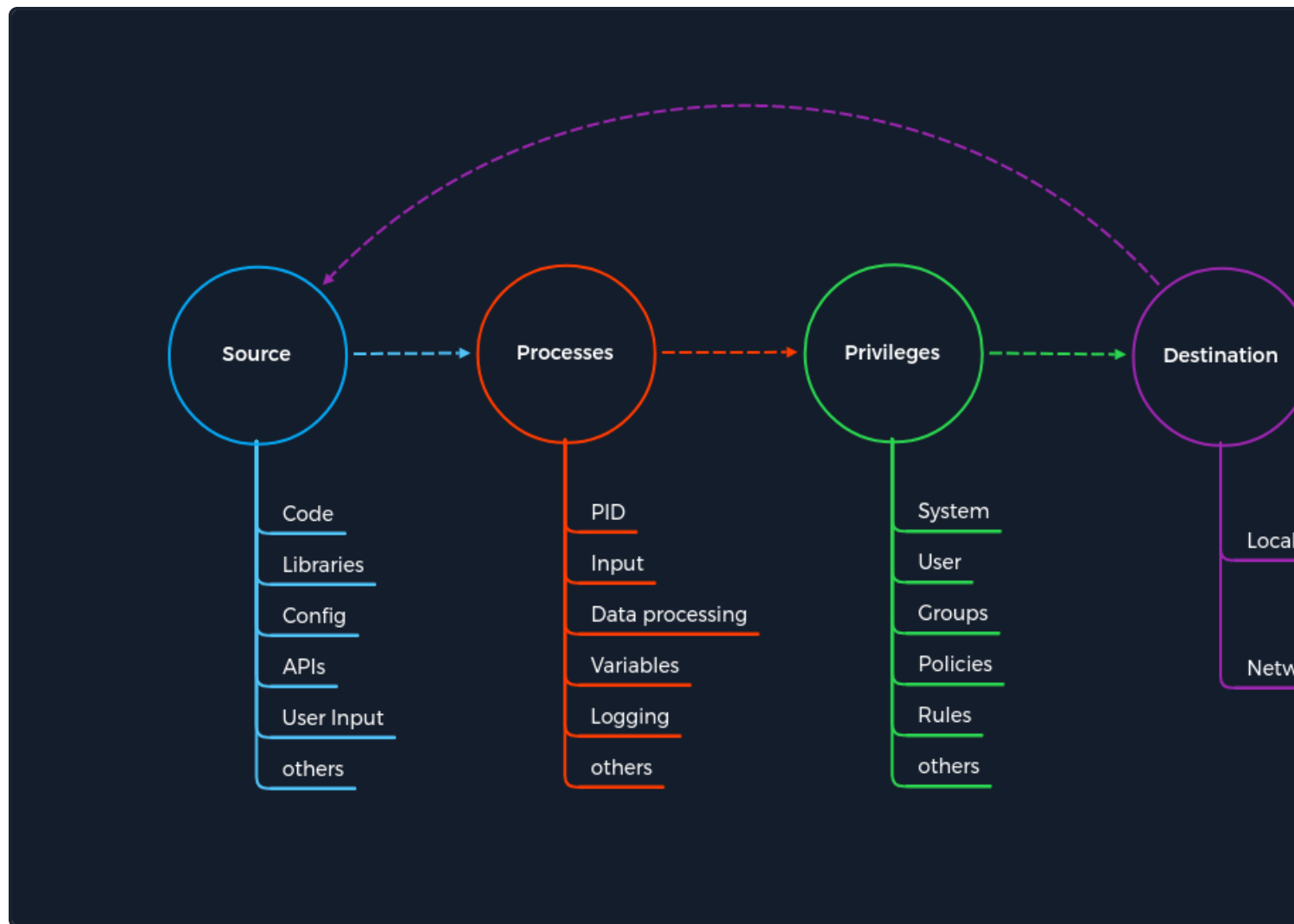
424,120

total possible subdomain
takeover were identified at the

possible subdomains
existing in A

this nonexistent domain, the subdomain points to the domain registration by us. By making a single DNS owner of that particular subdomain, and after that, we can manage the subdomain as we choose.

The Concept of Attacks



What happens here is that the existing subdomain no longer points to a third-party provider and is therefore under our control. Pretty much anyone can register this subdomain as their own. Visiting this subdomain and the page it points to, which is the company's DNS leads, in most cases, to things working as expected. However, the design and functionality are now in the hands of the attacker.

Initiation of Subdomain Takeover

Step Subdomain Takeover

1. The source, in this case, is the subdomain name that is no longer used by the company that we discovered.

domain and its DNS servers. Since this subdomain is in the list, the DNS server considers the subdomain as trustworthy and forwards the visitor.

8. The destination here is the person who requests the IP address of the subdomain where they want to be forwarded via the network.

Subdomain takeover can be used not only for phishing but also for many other attacks. These include, for example, cross-site request forgery (CSRF), abusing CORS, and defeating content security policy (CSP). We can see many subdomain takeovers on the [HackerOne website](#), which have earned the bug bounty hunters considerable payouts.

[← Previous](#)[Next →](#)

+10 Strea

 [Cheat Sheet](#) [Resources](#)

Table of Contents

Introduction

Interacting with Common Services

Protocol Specific Attacks

The Concept of Attacks

Service Misconfigurations

Finding Sensitive Information

FTP

 [Attacking FTP](#)

Latest FTP Vulnerabilities

SMB

 [Attacking SMB](#)

Latest SMB Vulnerabilities

SQL Databases

Skills Assessment

-  Attacking Common Services - Easy
-  Attacking Common Services - Medium
-  Attacking Common Services - Hard

My Workstation

O F F L I N E

 Start Instance

 / 1 spawns left